

Arquitetura de Controle de Acesso

Assessoria Águia — Sistema de Gestão de Assessoria Parlamentar

Gerado em 28/09/2026

1. Objetivo

Implementar um sistema de acesso com **dois níveis hierárquicos**, permitindo que cada assessor gerencie apenas os seus próprios dados e que o vereador / chefe de gabinete supervisione o trabalho de toda a equipe.

2. Níveis de Acesso (Perfis)

Assessor (usuário comum)

- Login individual (credenciais próprias).
- Vê e gerencia **apenas os seus próprios** contatos, demandas e ofícios.
- Não enxerga o trabalho dos demais assessores.
- Gera os próprios relatórios trimestrais.

Vereador / Chefe de Gabinete (administrador)

- Login com conta administrativa (senha mestre).
- Visualiza o trabalho de **todos os assessores**.
- Painel de supervisão: acompanha produtividade e cumprimento de tarefas.
- Filtra os dados por assessor.
- Cria, edita e desativa contas de assessores.
- Relatório consolidado de todo o gabinete.

3. Diagrama de Hierarquia



Cada contato, demanda e ofício fica vinculado ao assessor que o criou. O administrador tem visão agregada; os assessores têm visão isolada dos próprios dados.

4. Roteiro de Implementação (por etapas)

As mudanças serão adicionadas **aos poucos**, cada etapa com código, testes automatizados e envio ao repositório.

Etapa	Descrição	Prioridade
1	Modelo de Usuário com papéis (assessor / admin) e senhas protegidas por hash.	Essencial
2	Tela de login / logout e proteção de todas as rotas.	Essencial
3	Vincular contatos, demandas e ofícios ao assessor dono .	Essencial
4	Filtragem de dados: assessor vê os seus; admin vê todos.	Essencial
5	Painel do gestor : supervisão de produtividade por assessor.	Importante
6	Administração de contas: criar, editar e desativar assessores.	Importante

5. Considerações de Segurança

- Senhas nunca são armazenadas em texto puro — sempre com **hash** (ex.: bcrypt).
- Sessões seguras e proteção contra acesso não autorizado às rotas.
- Isolamento de dados entre assessores (um não acessa dados do outro).
- Recomendado: HTTPS, backups automáticos e banco PostgreSQL em produção.
- **LGPD**: como há dados pessoais, recomenda-se política de privacidade, base legal para o tratamento e mecanismo de exclusão a pedido do titular. Consultar profissional jurídico.

Documento de planejamento técnico. As definições podem ser ajustadas conforme a evolução do projeto.